



LarShield Security Audit Report



VULNERABILITY ASSESSMENT & PENETRATION TESTING (VAPT) REPORT

Target Asset / Application : <https://api.larxius.com/v1>
Assessment Type : API Security Assessment
Date of Testing : August 07, 2026
Report Version : v1.0
Report Status : Final
Classification : Confidential

Prepared by:

LarShield
[Larxius Technologies LLP]
info@Larxius.com
www.Larxius.com



Executive summary

This report presents the results of the API Security Assessment for <https://api.larxius.com/v1>. The recommendations provided in this report are structured to facilitate the remediation of the identified security risks. This document serves as a formal letter of attestation for the recent engagement. The assessment revealed a critical exposure in the perimeter, with 1 Critical and 1 High severity vulnerabilities identified. Immediate remediation is required to prevent potential compromise. We highly recommend reviewing the section of Summary of business risks and High-Level Recommendations for a better understanding of risks and discovered security issues.

Scope

Scope	Security level	Grade
Web API perimeter	Inadequate	F

Under Defense Grading Criteria:

Grade	Security	Criteria Description
A	Excellent	The security exceeds "Industry Best Practice" standards. The overall posture was found to be excellent with only a few low-risk findings identified.
B	Good	The security meets with accepted standards for 'Industry Best Practice.' The overall posture was found to be strong with only a handful of medium- and low-risk shortcomings identified.
C	Fair	Current solutions protect some areas of the enterprise from security issues. Moderate changes are required to elevate the discussed areas to "Industry Best Practice" standards.
D	Poor	Significant security deficiencies exist. Immediate attention should be given to the discussed issues to address exposures identified. Major changes are required to elevate to "Industry Best Practice" standards.
F	Inadequate	Serious security deficiencies exist. Shortcomings were identified throughout most or even all of the security controls examined. Improving security will require a major allocation of resources.

Assumptions & Constraints

As the environment changes, and new vulnerabilities and risks are discovered and made public, an organization's overall security posture will change. Such changes may affect the validity of this letter. Therefore, the conclusion reached from our analysis only represents a 'snapshot' in time.



Objectives & Scope

Organization	Dhruvpatel14016 Organization
Audit type	API Security Assessment
Asset URL	https://api.larxius.com/v1
Audit Date	August 07, 2026

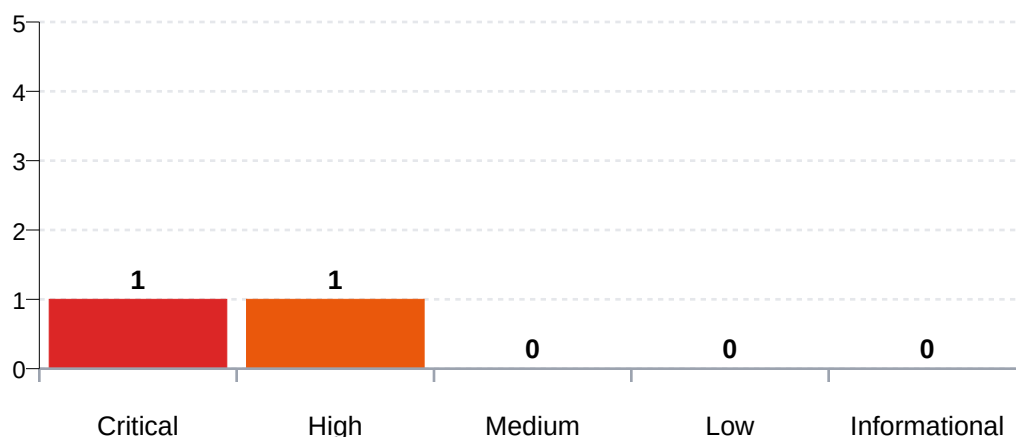
Testing Process:

Consultants performed a discovery process to gather information about the target and searched for information disclosure vulnerabilities. With this data in hand, we conducted the bulk of the testing manually, which consisted of input validation tests, impersonation (authentication and authorization) tests, and session state management tests. The purpose of this penetration testing is to illuminate security risks by leveraging weaknesses within the environment that lead to the obtainment of unauthorized access and/or the retrieval of sensitive information. The shortcomings identified during the assessment were used to formulate recommendations and mitigation strategies for improving the overall security posture.

Results Overview

The test uncovered a few vulnerabilities that may cause sensitive data leakage, broken confidentiality and integrity, and availability of the resource. Identified vulnerabilities are easily exploitable and the risk posed by these vulnerabilities can cause damage to the application and company. Security experts performed manual security testing according to OWASP Web Application Testing Methodology, which demonstrates the following results.

Critical	High	Medium	Low	Informational
1	1	0	0	0



Severity scoring definitions:

- Critical - Immediate threat to key business processes.
- High - Direct threat to key business processes.



- Medium - Indirect threat to key business processes or partial threat to business processes.
- Low - No direct threat exists. Vulnerability may be exploited using other vulnerabilities.
- Informational - This finding does not indicate vulnerability, but states a comment that notifies about design flaws and improper implementation that might cause a problem in the long run.

Scan Coverage Note:

This is a **Deep Scan**. This is our most advanced, best-in-class scanning engine. It executes our complete arsenal of scripts, fuzzers, and deep-crawling tools to rigorously analyze the entire website and provide a comprehensive security evaluation. It identifies even deeply hidden or chained vulnerabilities for maximum protection.



Vulnerability Summary

Click on any vulnerability title or page number below to jump directly to its detailed section in this report.

1. API1:2023 Broken Object Level Authorization (BOLA)	[Critical]	10
2. API4:2023 Unrestricted Resource Consumption	[High]	11



Summary of business risks

Critical and High severity issues can lead to:

- Complete compromise of the application and underlying systems, leading to total loss of data confidentiality and integrity.
- Significant financial loss, reputational damage, and legal consequences due to regulatory violations.
- Complete disruption of key business processes and denial of service to legitimate users.
- Unauthorized access to sensitive user data and intellectual property.

Medium and low severity issues can lead to:

- Attacks on communication channels and as a result on sensitive data leakage and possible modification; in other words, it affects the integrity and confidentiality of data transferred.
- Information leakage about system components which may be used by attackers for further malicious actions.
- Attacks on old and unpatched system components with a bunch of publicly known vulnerabilities.
- Enumerating existing users' emails/usernames and brute-forcing their passwords. Easy access to their session after exploitation of high-level risks.
- Combination of a few issues can be used for successful realization of attacks.
- Informational severity issues do not carry a direct threat, but they can be used to gather useful information for an attacker.

High-Level Recommendations

Taking into consideration all issues that have been discovered, we highly recommend to:

- Conduct current vs. future IT/Security program review
- Conduct Static code analysis for codebase
- Establish Secure SDLC best practices, assign Security Engineer to a project to monthly review code, conduct SAST & DAST security testing
- Review Architecture of application
- Deploy Web Application Firewall solution to detect any malicious manipulations
- Continuously monitor logs for anomalies to detect abnormal behaviour and fraud transactions. Dedicate a security operations engineer to this task
- Implement Patch Management procedures for whole IT infrastructure and endpoints of employees and developers
- Continuously Patch production and development environments and systems on regular bases with latest releases and security updates
- Conduct annual Penetration test and quarterly Vulnerability Scanning against internal and external environment
- Develop and Conduct Security Awareness training for employees and developers
- Develop Incident Response Plan in case of Data breach or security incidents
- Analyse risks for key assets and resources
- Update codebase to conduct verification and sanitization of user input on both, client and server side
- Use only encrypted channels for communications



Web Application VAPT Report



- Do not send any unnecessary data in requests and cookies
- Improve server and application configuration to meet security best practises



Performed tests

- All set of applicable OWASP Top 10 Security Threats
- All set of applicable SANS 25 Security Threats

A1:2017-Injection	Evaluated	Injection Flaws
A2:2017-Broken Authentication	Evaluated	Authentication Issues
A3:2017-Sensitive Data Exposure	Evaluated	Data Protection
A4:2017-XML External Entities (XXE)	Evaluated	XML Processors
A5:2017-Broken Access Control	Evaluated	Access Control
A6:2017-Security Misconfiguration	Evaluated	System Configuration
A7:2017-Cross-Site Scripting (XSS)	Evaluated	Client-side Flaws
A8:2017-Insecure Deserialization	Evaluated	Deserialization
A9:2017-Using Components with Known Vulnerabilities	Evaluated	Vulnerable Components
A10:2017-Insufficient Logging & Monitoring	Evaluated	Logging

Methodology

Our Penetration Testing Methodology is grounded on the following guides and standards:

- Penetration Testing Execution Standard
- OWASP Top 10 Application Security Risks - 2017
- OWASP Testing Guide
- OWASP ASVS

Methodology Overview: Open Web Application Security Project (OWASP) is an industry initiative for web application security. OWASP has identified the 10 most common attacks that succeed against web applications. These comprise the OWASP Top 10. Application penetration test includes all the items in the OWASP Top 10 and more. The penetration tester remotely tries to compromise the OWASP Top 10 flaws. The flaws listed by OWASP in its most recent Top 10 and the status of the application against those are depicted in the table above.

SSL/TLS Analysis

Could not retrieve SSL certificate details.



Findings Details

1. API1:2023 Broken Object Level Authorization (BOLA)

Severity	Critical	CVSS Score	9.1
Category	Authorization	Detected	2026-08-07
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/\$:U/C:H/I:H/A:H		

Description:

BOLA occurs when an API endpoint does not validate if the currently authenticated user has the rights to access or modify a specific object requested by ID. This is the #1 API risk according to OWASP.

Proof of Detection (Engine Payload Audit Log):

```
# Request Details
GET /api/users/102 HTTP/1.1
Host: api.larxius.com
Authorization: Bearer <User A Token>

# Response Details
200 OK
{"user_id": 102, "email": "victim@example.com"}

# Evidence
User A (ID=101) requested User B's profile by changing the URL to `/api/users/102`. The API successfully returned User B's private data.
```

Remediation:

Implement authorization checks on every endpoint that accesses an object by ID.
Ensure the user ID extracted from the auth token matches the owner of the requested object.



2. API4:2023 Unrestricted Resource Consumption

Severity	High	CVSS Score	7.8
Category	Availability	Detected	2026-08-07
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H		

Description:

The API does not impose restrictions on the amount of resources requested by the client (e.g., no rate limits, missing pagination limits, large file uploads allowed).

Proof of Detection (Engine Payload Audit Log):

```
# Request Details
GET /api/transactions?limit=1000000

# Response Details
200 OK
[... 1000000 records ...]

# Evidence
Requested 1,000,000 records from the `/api/transactions` endpoint in a single request, causing significant server lag.
```

Remediation:

Implement strict rate limiting, payload size limits, and enforce pagination on endpoints that return lists (e.g., max 100 items per request).